

Glossary: Penetration Testing: Attack Phase

Welcome! This alphabetized glossary contains many of the terms in this module. This comprehensive glossary also includes additional industry-recognized terms not used in course videos. These terms are important for you to recognize when working in the industry, participating in user groups, and participating in other certificate programs.

Term	Definition
Address resolution protocol (ARP)	A protocol used to map an IP (Internet Protocol) address to a physical MAC (media access control) address on a local area network.
Attack	An intentional act aimed at exploiting vulnerabilities or weaknesses in a system, network, or application to compromise its security.
Attack phase	The third phase of penetration testing in which ethical hackers simulate real-world attacks to identify vulnerabilities and evaluate a system's security.
Bandwidth	The maximum rate of data transfer across a network path.
Brute-force attack	An attempt to crack a password or encryption key by systematically trying all possible combinations.
Buffer overflow	A vulnerability that occurs when a program writes more data to a buffer than it can hold, potentially allowing attackers to execute arbitrary code.
Client closeout	The formal presentation of findings and recommendations to the client, post-preparation of the pen testing report, followed by a discussion of the results and completion of all administrative and data handling tasks.
Command injection	An attack that allows the execution of arbitrary commands on a host operating system through a vulnerable application.
Cyber threat	A potential danger or risk that can exploit vulnerabilities in information systems or networks.
Data exfiltration	The unauthorized transfer of data from a computer or network.
Distributed denial of service (DDoS)	An attack that aims to make a system or network resource unavailable to its intended users by overwhelming it with traffic.
Discovery phase	The initial phase in penetration testing, where testers gather information about the target system, including network mapping, service enumeration, and vulnerability scanning.
Dynamic Host Configuration Protocol (DHCP)	A network management protocol used to automatically assign IP addresses and other network configuration parameters to devices on a network.
Dynamic port	A port typically used for temporary or private network connections.
Encryption	The process of converting plain text into ciphertext to prevent unauthorized access to the data.
Exfiltration phase	The fourth phase in penetration testing where identified vulnerabilities are actively exploited to gain unauthorized access or control over a system.
Exploitation tool	A software tool used to exploit vulnerabilities in systems, applications, or networks during penetration testing.
File Transfer Protocol (FTP)	A protocol used to transfer files between a client and server on a network, typically using port 20 for data transfer and port 21 for control commands.
Firewall	A network security device or software that monitors and controls incoming and outgoing network traffic based on predetermined security rules.
Intelligence gathering	The process of collecting information about a target system or organization to identify potential attack vectors and vulnerabilities.
Intrusion detection system (IDS)	A system that monitors network or system activities for malicious activities or policy violations.
Kismet	A wireless network detector, sniffer, and intrusion detection system used to detect and analyze wireless networks and identify unauthorized access points.
Network address translation (NAT)	A method used by routers to translate private IP addresses into public IP addresses and vice versa.
Network mapper (Nmap)	A network scanning tool used to discover hosts and services on a computer network by sending packets and analyzing the responses.
Penetration testing	A simulated cyberattack against a computer system or network to identify and exploit vulnerabilities.
Phishing	A social engineering attack that aims to deceive individuals into revealing personal information, such as passwords or credit card numbers, by masquerading as a trustworthy entity.
Protocol	A set of rules that govern data communication between devices on a network.
Red teaming	An approach to security testing that simulates an adversarial attack to assess the effectiveness of security measures and incident response capabilities.

Term	Definition
Security Information and Event Management (SIEM)	A solution that provides real-time analysis of security alerts generated by applications and network hardware.
Software Development Life Cycle (SDLC)	A process that defines the stages involved in developing software applications, including planning, design, coding, testing, and deployment.



Skills Network